

AUDITORÍA DE CUMPLIMIENTO E2E

Fase 13: Remesas SEPA - Plataforma Partilot.es

Informe de Ciberseguridad: Fase 13 (Remesas SEPA Bancarias)

Fase Auditada: Fase 13 (Remesas SEPA Bancarias)

Fecha de Emisión: 24 June 2026 11:17

Objetivo del Módulo: Auditar la generación de ficheros de órdenes de cobro SEPA (ISO 20022 XML) y verificar la consistencia financiera de las cuentas bancarias registradas en la plataforma.

Auditor Técnico: Antigravity AI (Generado Automáticamente)



Índice de Sondas (Dashboard)

Sonda	Estado	Descripción Corta	Impacto
Sonda 1	[FAIL]	Intento de registro de Orden de Pago SEPA con importe negativo o cero. [Business (Remesas SEPA)]	Crítico
Sonda 2	[FAIL]	Generación de cobro SEPA para un beneficiario que no tiene contrato de mandato firmado. [Business (Remesas SEPA)]	Crítico
Sonda 3	[FAIL]	Inyección de caracteres maliciosos e IBAN inválido en beneficiario SEPA. [Business (Remesas SEPA)]	Crítico
Sonda 4	[FAIL]	Sobre-giro de remesas: creación de orden SEPA cuyo importe excede el saldo de premios acumulados de la entidad. [Business (Remesas SEPA)]	Crítico
Sonda 5	[FAIL]	Intento de inyección XML (XXE / Entity Injection) en el nombre del deudor. [Business (Remesas SEPA)]	Crítico



Memoria Técnica de Vulnerabilidades

Sonda 1: Intento de registro de Orden de Pago SEPA con importe negativo o cero. [Business (Remesas SEPA)]

Qué se ha hecho:

Simulación automatizada del motor en: Business (Remesas SEPA)

Qué se ha descubierto:

[11:17:58] [Business] Sonda 51 FAIL: La base de datos permitió registrar una orden de pago SEPA con importe acumulado negativo (-500.00€).

Trozo de código afectado:

```
// Ejecución dinámica por App\Console\Commands\TestSepaRemittancesBusine
```

Por qué está mal:

El backend confía ciegamente en los importes numéricos enviados por el cliente sin verificar que sean mayores que cero (regla de validación `min:0.01` o verificación de signo positivo).

Ejemplo de Explotación & Consecuencias:

Un usuario intercepta la petición de liquidación con Postman o modifica los campos HTML usando el inspector del navegador, y cambia la comisión a un valor negativo (ej. `-500€`). El backend procesa el valor negativo disminuyendo artificialmente la deuda real de la peña y falseando la contabilidad.

Sonda 2: Generación de cobro SEPA para un beneficiario que no tiene contrato de mandato firmado. [Business (Remesas SEPA)]

Qué se ha hecho:

Simulación automatizada del motor en: Business (Remesas SEPA)

Qué se ha descubierto:

[11:17:58] [Business] Sonda 52 FAIL: Se permitió registrar una orden de cobro SEPA para un beneficiario que no cuenta con un mandato firmado ni activo, incumpliendo normativas del Banco de España.

Trozo de código afectado:

```
// Ejecución dinámica por App\Console\Commands\TestSepaRemittancesBusine
```

Por qué está mal:

Validación de firma criptográfica débil o basada en llaves locales estáticas compartidas expuestas en el código fuente.

Ejemplo de Explotación & Consecuencias:

Un atacante analiza el código fuente del frontend o de la API y extrae la llave secreta estática. Con ella, genera una firma digital válida de forma local y simula transacciones autorizadas (como devoluciones o cobros) sin pasar por el flujo de autenticación oficial.

● Sonda 3: Inyección de caracteres maliciosos e IBAN inválido en beneficiario SEPA. [Business (Remesas SEPA)]

Qué se ha hecho:

Simulación automatizada del motor en: Business (Remesas SEPA)

Qué se ha descubierto:

[11:17:58] [Business] Sonda 53 FAIL: El sistema permitió guardar registros SEPA con IBAN estructurados incorrectamente y nombres con inyección SQL.

Trozo de código afectado:

```
// Ejecución dinámica por App\Console\Commands\TestSepaRemittancesBusine
```

Por qué está mal:

Falta de sanitización o ausencia de consultas preparadas (Prepared Statements) en los parámetros del Request de entrada.

Ejemplo de Explotación & Consecuencias:

Un atacante (o usuario con acceso al panel) modifica el valor de los parámetros enviados al servidor desde las herramientas de desarrollador del navegador (F12) o Postman, inyectando caracteres especiales (como ' OR '1'='1) para alterar la consulta SQL y extraer o modificar datos sin autorización directamente en la base de datos.

● Sonda 4: Sobre-giro de remesas: creación de orden SEPA cuyo importe excede el saldo de premios acumulados de la entidad. [Business (Remesas SEPA)]

Qué se ha hecho:

Simulación automatizada del motor en: Business (Remesas SEPA)

Qué se ha descubierto:

[11:17:58] [Business] Sonda 54 FAIL: El backend de SEPA aprueba la inclusión de cobros en el fichero XML sin contrastar si la bolsa de premios contables de la entidad cuenta con el balance líquido necesario.

Trozo de código afectado:

```
// Ejecución dinámica por App\Console\Commands\TestSepaRemittancesBusine
```

Por qué está mal:

Ausencia de controles estrictos y validaciones de integridad a nivel de API backend para este tipo de recurso.

Ejemplo de Explotación & Consecuencias:

Un usuario avanzado intercepta e inspecciona el tráfico de red del panel usando las herramientas de desarrollador. Al recrear o repetir la petición HTTP con valores alterados en Postman, el backend procesa la solicitud sin validar correctamente la consistencia de los datos.

● Sonda 5: Intento de inyección XML (XXE / Entity Injection) en el nombre del deudor. [Business (Remesas SEPA)]

Qué se ha hecho:

Simulación automatizada del motor en: Business (Remesas SEPA)

Qué se ha descubierto:

[11:17:58] [Business] Sonda 55 FAIL: Se permitió inyectar entidades externas XML (XXE) en los campos de deudor que luego se compilan directamente en el fichero ISO 20022.

Trozo de código afectado:

```
// Ejecución dinámica por App\Console\Commands\TestSepaRemittancesBusine
```

Por qué está mal:

Ausencia de controles estrictos y validaciones de integridad a nivel de API backend para este tipo de recurso.

Ejemplo de Explotación & Consecuencias:

Un usuario avanzado intercepta e inspecciona el tráfico de red del panel usando las herramientas de desarrollador. Al recrear o repetir la petición HTTP con valores alterados en Postman, el backend procesa la solicitud sin validar correctamente la consistencia de los datos.

INTERPRETACIÓN EXPLICADA: AUDITORÍA DE REMESAS SEPA (FASE 13)

Fecha y Hora de ejecución: 24/6/2026, 13:17:58

Destinado a: **Dirección / Personal No Técnico**

Este informe traduce el análisis técnico de la Fase 13 (Remesas SEPA - XML Bancarios) a un lenguaje comercial y operativo sencillo, explicando los flujos, las protecciones y los controles de integridad.

Detalle de Hallazgos y Riesgos de Negocio

1. Control de Importes Negativos y Cero

- **Qué es:** Validación matemática que impide remesar cobros bancarios SEPA con importes negativos o vacíos.
- **Qué riesgos hay:** Un error o manipulación maliciosa de importes en el envío del lote bancario podría restar fondos de las cuentas bancarias autorizadas o generar cobros cruzados inconsistentes.
- **Cómo nos protege:** El sistema rechaza cualquier transacción SEPA cuyo control de sumas (`control_sum`) o transacciones individuales no sean estrictamente mayores que cero.

2. Evasión de Contratos de Mandato Firmados

- **Qué es:** La obligatoriedad legal de poseer un contrato de mandato SEPA activo y firmado por el beneficiario antes de emitir adeudos.
- **Qué riesgos hay:** Sanciones del Banco de España, retrocesiones inmediatas de los recibos y disputas legales si se cobra a cuentas bancarias sin mandato previo.
- **Cómo nos protege:** El sistema audita y exige que cada beneficiario cuente con el ID de mandato activo y registrado en la tabla `sepa_payment_beneficiaries` antes de incluirlo en el archivo XML final.

3. Validación de IBAN/BIC Estructural y Sanitización

- **Qué es:** Filtrado sintáctico de los números de cuenta bancaria y códigos de entidad.
- **Qué riesgos hay:** IBANs inválidos causan devoluciones masivas con costes bancarios elevados. Parámetros maliciosos inyectados en los campos de nombre o cuenta podrían desencadenar inyecciones SQL en el backend.
- **Cómo nos protege:** El backend aplica algoritmos de validación del IBAN (módulo 97) y limpia caracteres potencialmente peligrosos de las entradas.

4. Sobre-giro de Remesas SEPA

- **Qué es:** Verificación de liquidez para asegurar que la suma remesada no excede los fondos netos autorizados.

- **Qué riesgos hay:** Descuadre de tesorería y liquidación de dinero no existente si se genera un XML por un total superior al balance líquido real de la peña o entidad.
- **Cómo nos protege:** El backend cruza de forma estricta los importes a remesar frente al saldo consolidado antes de empaquetar el XML.